

*ISO*



*Shweta A. Chawla*  
*Founder & Investigator*  
*SC Cyber Solutions*

# ISO



- ❶ International Organisation of Standards
- ❷ ISO is an independent organization
- ❸ Develops and publishes international standards
- ❹ Not linked to any government
- ❺ ISO comes from the Greek word '*isos*' meaning *equal*
- ❻ Includes national standards bodies from 162 countries (eg: Bureau of Indian Standards)
- ❼ Individuals or companies cannot become members of ISO

## ISO/IEC 27000



- ❶ Family of standards for information security management systems (ISMS)
- ❷ More than a dozen standards
- ❸ Jointly published by the International Organization for Standardization (ISO) and the International Electrotechnical Commission (IEC) in 2005
- ❹ Revised in 2013
- ❺ European update in 2017

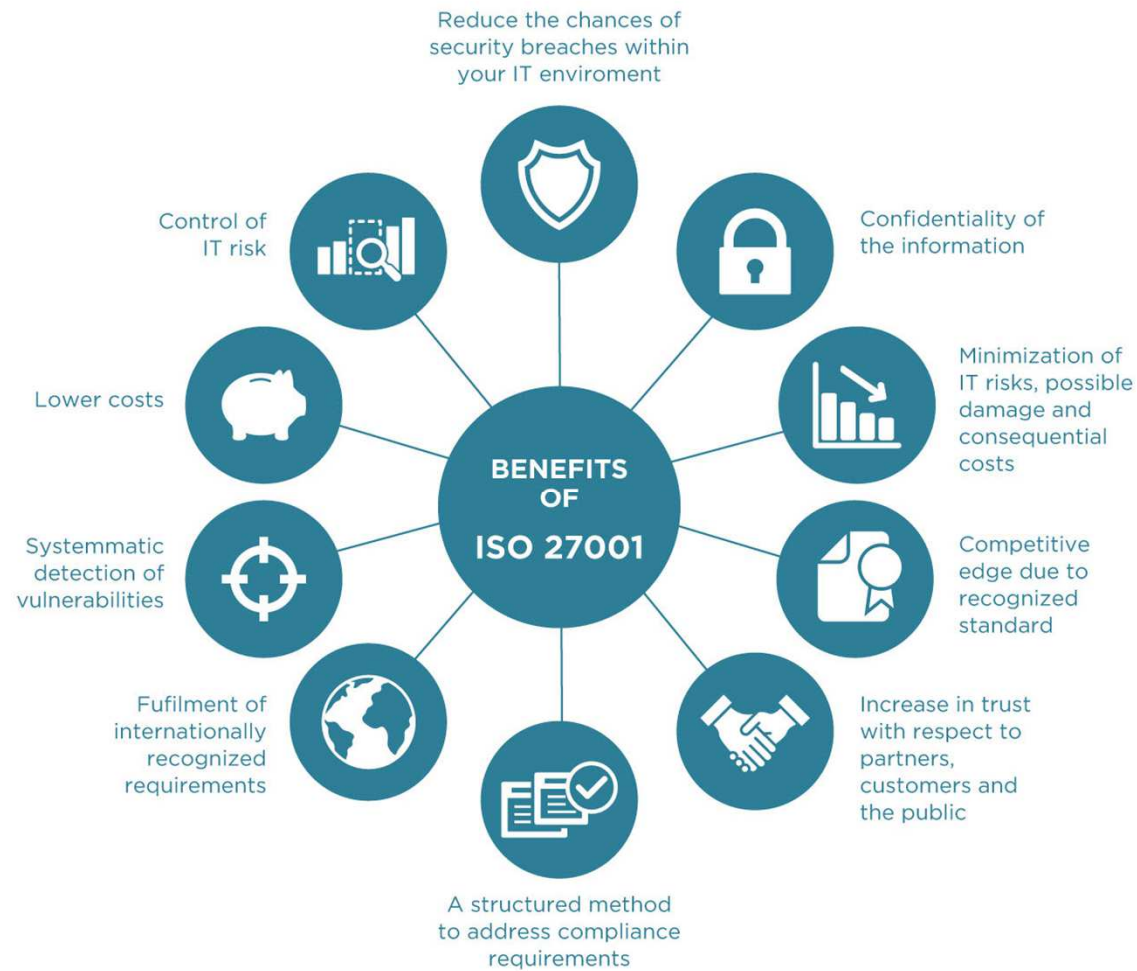
# ISO/IEC 27001



- ❶ ISO/IEC 27001 requires that management:
  - ❶ Systematically examine the organization's information security risks, taking account of the threats, vulnerabilities, and impacts;
  - ❷ Design and implement a coherent and comprehensive suite of information security controls and/or other forms of risk treatment (such as risk avoidance or risk transfer) to address those risks that are deemed unacceptable; and
  - ❸ Adopt an overarching management process to ensure that the information security controls continue to meet the organization's information security needs on an ongoing basis.



- ❶ Annex A of the standard provides a list of controls and their objectives
- ❷ 114 controls in 14 groups
- ❸ 35 control categories





- ❶ A.5: Information security policies (2 controls)
- ❷ A.6: Organization of information security (7 controls)
- ❸ A.7: Human resource security - 6 controls that are applied before, during, or after employment
- ❹ A.8: Asset management (10 controls)
- ❺ A.9: Access control (14 controls)
- ❻ A.10: Cryptography (2 controls)
- ❼ A.11: Physical and environmental security (15 controls)
- ❽ A.12: Operations security (14 controls)
- ❾ A.13: Communications security (7 controls)
- ❿ A.14: System acquisition, development and maintenance (13 controls)
- ⓫ A.15: Supplier relationships (5 controls)
- ⓬ A.16: Information security incident management (7 controls)
- ⓭ A.17: Information security aspects of business continuity management (4 controls)
- ⓮ A.18: Compliance; with internal requirements, such as policies, and with external requirements, such as laws (8 controls)





# ISO/IEC 27001 Implementation Process



- ✔ Assemble an implementation team
- ✔ Develop the implementation plan
- ✔ Initiate the ISMS
- ✔ Define the ISMS scope
- ✔ Identify the security baseline
- ✔ Establish a risk management process
  - ✔ Establish a risk assessment framework
  - ✔ Identify risks
  - ✔ Analyse risks
  - ✔ Evaluate risks
  - ✔ Select risk management options
- ✔ Implement a risk treatment plan
- ✔ Measure, monitor and review
- ✔ Certify the ISMS





# ISMS Methodology



*Thank You!*

Contact details:

Mob: +91 98230 80864

[shweta@sccybersolutions.com](mailto:shweta@sccybersolutions.com)

[www.sccybersolutions.com](http://www.sccybersolutions.com)

[@sccs1300](#)

